Mini Product Backlog – NHI Platform

1. Overview

The Certificate Inventory & Lifecycle Management module enables platform administrators and security teams to monitor, manage, and control TLS certificates used across the NHI platform. The module provides capabilities to:

- View and monitor all certificates stored in the system
- Filter and search certificates to identify risks (e.g., expiring certificates)
- Perform lifecycle operations such as certificate revocation
- Support enterprise-scale environments with large certificate inventories
- Enforce Role-Based Access Control (RBAC) across tenants and user roles

The system must handle large certificate inventories (10K+ certificates) while ensuring data security, performance, and tenant isolation.

2. Epics

Epic 1: Inventory Visibility

This epic focuses on providing users with visibility into all TLS certificates stored in the system. It includes listing, searching, filtering, and monitoring certificate inventory.

Key goals:

- Provide a scalable certificate inventory dashboard
- Enable filtering and searching across large datasets
- Identify expiring or compromised certificates quickly

Epic 2: Certificate Lifecycle Actions

This epic focuses on enabling users to perform lifecycle operations on certificates.

Key capabilities:

- Revoke compromised certificates
- Perform bulk revocation operations
- Initiate certificate renewal workflows

These actions help maintain security compliance and operational reliability.

Epic 3: Access Control & Security

This epic ensures secure access to certificate data by enforcing Role-Based Access Control (RBAC) and tenant-level data isolation.

Key goals:

- Prevent cross-tenant data exposure
- Restrict actions based on user roles
- Maintain audit trails for all certificate operations

3. User Stories (Prioritized Backlog)

Priority Level P0 – Core MVP Features

These stories are essential to deliver the minimum viable version of the certificate management system.

CINV-101: Certificate Inventory Dashboard

Epic: Inventory Visibility

Title: View certificate inventory dashboard

Description

As a Security Administrator, I want to view a dashboard that lists all TLS certificates for my tenant so that I can monitor certificate health and identify expiration risks before they cause service disruptions.

Acceptance Criteria

1. The dashboard displays a table containing the following columns:
    - Domain / Common Name
    - Issuer
    - Certificate Status (Valid, Expiring, Revoked)
    - Expiration Date
    - Serial Number
2. The dashboard must support pagination or infinite scrolling to load large inventories.
3. The system must be able to load and display 10,000+ certificates in under 3 seconds.
4. An empty state screen must be displayed when a tenant has no certificates.
5. The dashboard must be responsive and usable on desktop, tablet, and mobile devices.
6. Each certificate row should allow navigation to the detailed certificate view.

Technical Notes

- Uses existing backend API: GET /certificates
- Implement virtual scrolling in the frontend to support large datasets
- Add database indexing for fields such as:
    - expiration date
    - domain
    - issuer

CINV-201: Single Certificate Revocation

Epic: Certificate Lifecycle Actions

Title: Revoke individual certificate

Description

As a Security Administrator**,** I want to revoke a specific TLS certificate so that compromised or invalid certificates can be immediately disabled to prevent security incidents.

Acceptance Criteria

1. Each certificate row in the dashboard contains a **"**Revoke" action button.
2. Clicking revoke triggers a two-step confirmation dialog to avoid accidental revocation.
3. The user must provide a revocation reason before confirming.
4. After revocation:
    - Certificate status changes to Revoked
    - UI updates immediately (optimistic update)
    - Backend confirmation syncs status
5. A success notification (toast**)** is displayed to the user.
6. An audit log entry must be created containing:
    - user ID
    - certificate ID
    - timestamp
    - revocation reason
7. If revocation fails, an error message appears and the user may retry.

Technical Notes

- Uses backend endpoint:
  POST /certificates/{id}/revoke
- Revocation must be idempotent (multiple revoke requests should not cause errors).

CINV-301: Tenant RBAC Filtering

Epic: Access Control & Security

Title: Enforce tenant-based RBAC filtering

Description

As a Platform Administrator, I want certificate access to be restricted based on tenant and user roles so that organizations cannot view or manipulate certificates belonging to other tenants.

Acceptance Criteria

1. Backend APIs must filter certificates using tenant information from JWT tokens**.**

2. Users should only see certificates belonging to their assigned tenant.
3. Role-based permissions must be enforced:
4. Unauthorized actions must return a 403 Forbidden response.
5. All access and actions must be recorded in the audit log.

Technical Notes

- Integrate RBAC middleware using JWT token claims.
- Tenant ID extracted from authentication token.

Priority Level P1 – Scalability & Usability

These stories improve usability and support enterprise-scale operations.

CINV-102: Advanced Certificate Filtering

Epic: Inventory Visibility

Title: Filter certificates by status and expiry

Description

As a Security Administrator, I want to filter certificates by expiration window, status, and domain pattern so that I can quickly identify certificates that require attention.

Acceptance Criteria

1. Filters must support:

- Expiration windows (<30, <60, <90 days)
- Certificate status (Valid, Expiring, Revoked)
- Domain name pattern search
- Issuer

2. Filters can be combined simultaneously.
3. Results should update within 500ms after filter selection.
4. Filters should persist during the user's session.
5. Users should be able to export filtered results to CSV.

Technical Notes

- Client-side filtering for datasets under 1,000 records.
- Server-side filtering for larger datasets.

CINV-202: Bulk Certificate Revocation

Epic: Certificate Lifecycle Actions

Title: Revoke multiple certificates simultaneously

Description

As a Security Administrator**,** I want to revoke multiple certificates at once so that large numbers of expired or compromised certificates can be handled efficiently.

Acceptance Criteria

1. Users can select multiple certificates using checkbox selection**.**
2. A “Revoke Selected” button appears when items are selected.
3. Up to 100 certificates can be revoked in a single operation.
4. A progress bar shows operation status.
5. Partial failures must be reported individually.
6. An undo option (5-minute buffer) allows reversing accidental revocations.
7. An email notification is sent to the tenant owner when bulk revocation occurs.

Technical Notes

- Batch API endpoint:
  POST /certificates/bulk-revoke
- Operations should run asynchronous background jobs**.**

Priority Level P2 – Advanced Features & Enhancements

These features improve efficiency and enable mature enterprise workflows.

CINV-103: Smart Search & Sorting

Epic: Inventory Visibility

Title: Search and sort certificates

Description

As a Security Administrator, I want to search for certificates using domain names or serial numbers and sort results by expiration date or issuer so that I can quickly find specific certificates.

Acceptance Criteria

1. Users can search using:
   - Domain name
   - Serial number
   - Issuer name
2. The table supports sorting by:
   - Expiry date
   - Issuer
   - Date added
3. Multi-column sorting should be supported.
4. Keyboard shortcuts allow quick navigation.

5. A “Clear Filters” button resets search results.

Technical Notes

- Optional integration with Elastic search for full-text search.

CINV-302: Role-Based Action Visibility

Epic: Access Control & Security

Title: Display UI actions based on user role

Description

As a Platform Administrator, I want the UI to display only the actions permitted for a user’s role so that unauthorized users cannot attempt restricted operations.

Acceptance Criteria

Role UI Permissions – Viewer Read-only access

Manage Revoke + bulk revoke - All actions including role assignment

Additional requirements:

- Unauthorized actions should display friendly 403 messages
- UI elements must dynamically update when role changes.

Technical Notes

- Implement a frontend permission matrix**.**

CINV-303: Certificate Renewal Workflow

Epic: Certificate Lifecycle Actions

Title: Initiate certificate renewal

Description

As a Security Administrator**,** I want to initiate certificate renewal directly from the inventory so that expiring certificates can be replaced quickly.

Acceptance Criteria

1. A Renew button appears for certificates nearing expiration.
2. Clicking renew opens the certificate issuance workflow**.**
3. Domain and metadata fields are automatically pre-filled.
4. High-value domains require approval before issuance**.**

5. Renewal status must be tracked in the inventory dashboard.

Technical Notes

- Redirect to certificate issuance module.

4. Prioritization Rationale

The backlog is prioritized based on security impact, operational value, and dependencies**.**

P0 – Core Functionality

These features enable the basic certificate management workflow**:**

- Viewing certificate inventory
- Revoking compromised certificates
- Enforcing RBAC

Without these capabilities, administrators cannot monitor or control certificate security.

P1 – Operational Efficiency

These features support real-world enterprise usage patterns, including:

- Filtering large inventories
- Performing bulk operations

These workflows represent 80% of daily operational tasks for security teams.

P2 – Advanced Capabilities

These features enhance usability and enable mature security operations:

- Smart search
- Role-aware UI
- Certificate renewal workflows

They improve efficiency but are not required for the initial system launch.

5. Definition of Done (DoD)

A user story is considered complete when all the following criteria are satisfied.

Development

- Code is merged into the main branch
- Code passes peer review
- Unit test coverage is ≥95%

Testing

- All End-to-End tests pass
- No critical or high-severity defects

Performance

- System can load 10,000 certificates within 3 seconds
- Filtering results appear within 500 ms

Security

- RBAC policies validated
- No cross-tenant data leakage
- All sensitive actions logged in audit logs

Accessibility

- UI complies with WCAG 2.1 AA standards

Compatibility

- Verified on major browsers:
  - Chrome
  - Firefox
  - Safari
  - Edge

Documentation

- API documentation updated
- User guide created for certificate management workflows

QA Validation

- QA sign-off completed
- No open P0 or P1 defects

Release Readiness

- Feature validated in staging environment
- Monitoring dashboards configured